

REV	DATA	MOTIVO	ITENS MODIFICADOS
0	26/07/2023	Emissão inicial	Nenhum
1	19/02/2024	Tratamento da não conformidade 56703	Alterado item 5 inserindo responsável por acompanhar as reuniões do comitê.
2	17/03/2025	Alteração da composição do CSI e frequência de reunião do CSI	Item 6 e 7
3	09/02/2026	Reaprovação do documento	Nenhum

REV	DATA	APROVAÇÃO	
3	09/02/2026	CEO	

Este Documento e a informação nele contida são privativos das empresas Interjato Serviços Ltda e Interjato Telecomunicações Ltda. A reprodução de quaisquer partes deste Documento está condicionada à autorização por parte das organizações.

1. OBJETIVO.....	2
2. DEFINIÇÕES.....	3
3. CONTROLES DA ISO/IEC 27001 ASSOCIADOS A ESTE PROCEDIMENTO	3
4. DIRETRIZES GERAIS	3
5. COMPOSIÇÃO DO CSI.....	4
6. RESPONSABILIDADE E AUTORIDADE.....	5
a) Políticas de segurança da informação (A.5.01).....	5
b) Papéis e responsabilidades pela segurança da informação (A.5.02).....	5
c) Uso aceitável de informações e outros ativos associados (A.5.10).....	5
d) Segurança da informação nas relações com fornecedores (A.5.19).....	5
e) Planejamento e preparação da gestão de incidentes da segurança da informação (A.5.24).....	6
f) Avaliação e decisão sobre eventos da segurança da informação (A.5.25).....	6
g) Resposta a incidentes de segurança da informação (A.5.26).....	6
h) Aprendizado com incidentes de segurança da informação (A.5.27).....	6
i) Coleta de evidências (A.5.28).....	7
j) Segurança da informação durante a interrupção (A.5.29).....	7
k) Prontidão de TIC para continuidade de negócios (A.5.30).....	7
l) Requisitos legais, estatutários, regulamentares e contratuais (A.5.31).....	7
m) Direitos de propriedade intelectual (A.5.32).....	8
n) Análise crítica independente da segurança da informação (A.5.35).....	8
o) Compliance com políticas, regras e normas para segurança da informação (A.5.36).....	8
p) Processo disciplinar A.6.04.....	8
q) Trabalho remoto A.6.07.....	8
r) Relato de eventos de segurança da informação (A.6.08).....	9
s) Gestão de vulnerabilidades técnicas (A.8.08).....	9
t) Gestão de mudanças	9
7. DINÂMICA DE TRABALHO DO CSI.....	9
8. REGISTROS.....	10

1. OBJETIVO

Definir as atribuições do Comitê de Segurança da Informação (CSI) e a sistemática a ser adotada para sua atuação.

2. DEFINIÇÕES

- **ANPD** - Autoridade Nacional de Proteção de Dados
- **CSI** – Comitê de Segurança da Informação
- **Dado pessoal (DP)** – informação relacionada a pessoa natural identificada ou identificável; Informações podem ser consideradas DP pelo menos nos seguintes casos:
 - se elas contêm ou estão associadas a um identificador que se refere a uma pessoa natural (por exemplo, ao número do CPF);
 - se elas contêm ou estão associadas a um identificador que pode ser relacionado a uma pessoa natural (por exemplo, uma conta bancária);
 - se elas contêm ou estão associadas a um identificador que pode ser utilizado para estabelecer uma comunicação com uma pessoa natural identificada (por exemplo, uma localização geográfica precisa, um número de telefone);
 - se elas contêm uma referência que liga os dados a qualquer dos identificadores acima.

As informações também serão consideradas DP se contiverem ou estiverem associadas a uma característica que distingue uma pessoa natural de outras pessoas naturais (por exemplo, dados biométricos).

- **Disrupção** - Incidente, seja antecipado ou imprevisto, que interrompa o funcionamento regular das operações em um determinado local da organização.
- **Encarregado de Dados Pessoais (DPO)** – pessoa indicada pelo controlador para atuar como canal de comunicação entre o controlador, os titulares dos dados e a ANPD.
- **LGPD** – Lei Geral de Proteção de dados (Lei Nº 13709, de 14/08/2018).
- **SGSI** – Sistema de Gestão de Segurança da Informação.
- **SI** - Segurança da Informação

3. CONTROLES DA ISO/IEC 27001 ASSOCIADOS A ESTE PROCEDIMENTO

Ver item 6 deste procedimento

4. DIRETRIZES GERAIS

- Conforme descrito no item 6, o CSI possui papéis consultivos, deliberativos e executivos:
 - Consultivos – subsidiar outras instâncias decisórias com informações relacionadas à SI
 - Deliberativos – decidir de acordo com a autoridade citada no item 6 deste procedimento
 - Executivos – realizar ações de sua responsabilidade no âmbito da SI

- Todas as ações realizadas pelo CSI que envolvam o tratamento de dados pessoais deverão observar as regras estabelecidas pela LGPD e legislação específica da área de telecomunicações, onde aplicável.
- As decisões tomadas pelo CSI devem manter uma relação consistente com as estratégias de negócios da organização
- Para fins de preservação do histórico de tratativas e para agilizar as comunicações, o CSI fará uso de um grupo de trabalho específico na plataforma Bitrix. As comunicações, tarefas e demais registros neste grupo devem se ater às responsabilidades e autoridades do CSI.

5. COMPOSIÇÃO DO CSI

O Comitê de Segurança da Informação será composto por:

- Diretor
- DPO
- Gerente de Projetos
- Gerente de Implantação e Manutenção
- Gerente do NOC
- Gerente de SOC
- Supervisor de Suporte Técnico

A designação das pessoas que compõem o CSI será feita por Termo de Nomeação específico, emitido pela Diretoria.

Os membros do CSI poderão, a qualquer tempo, renunciar à sua participação no Comitê mediante solicitação à Diretoria, que decidirá sobre a substituição.

Colaboradores que não são membros do Comitê e especialistas externos poderão ser convidados para fornecer esclarecimentos ou informações sobre o(s) tema(s) discutidos.

Caso algum membro do Comitê encontre-se em situação em que possa haver conflito de interesses entre suas atividades e os trabalhos do CSI, este deverá manter-se afastado das atividades do CSI, enquanto perdurar a situação.

Durante os encontros do comitê deverá ter um representante do SOC que será responsável por realizar a ata da reunião conforme item 8 deste documento.

6. RESPONSABILIDADE E AUTORIDADE

As responsabilidades e autoridades do CSI estão descritas a seguir:

a) Políticas de segurança da informação (A.5.01)

Responsabilidade	Autoridade
• Revisar tecnicamente o conteúdo da política de segurança da informação e as políticas específicas por tema, em intervalo máximo de 12 meses. • Acompanhar o alcance dos objetivos de segurança da informação associados às diretrizes das políticas de SI	• Decidir quais as áreas temáticas específicas requerem políticas de segurança da informação • Aprovar as campanhas de conscientização sobre as políticas de SI

b) Papéis e responsabilidades pela segurança da informação (A.5.02)

Responsabilidade	Autoridade
• Coordenar a revisão do PG-02 (Descrição de funções) • Sugerir à Direção a necessidade de segregação de funções	• Decidir quais responsabilidades e autoridades comuns, relacionadas à SI, devem ser inseridas nas fichas de descrição de funções • Aprovar as campanhas de conscientização sobre a importância de conhecer e cumprir suas responsabilidades relacionadas à SI

c) Uso aceitável de informações e outros ativos associados (A.5.10)

Responsabilidade	Autoridade
• Conscientizar a força de trabalho sobre os requisitos de SI para proteger e lidar com as informações da organização e outros ativos associados	• Definir os requisitos de SI, associados ao uso aceitável de informações e outros ativos associados, devem ser incorporados nas políticas e procedimento internos, podendo incluir: a) comportamentos esperados e inaceitáveis dos indivíduos do ponto de vista de SI; b) uso permitido e proibido de informações e outros ativos associados;

d) Segurança da informação nas relações com fornecedores (A.5.19)

Responsabilidade	Autoridade
• Identificar os tipos de fornecedores que podem afetar a confidencialidade, integridade e disponibilidade das informações da organização • Analisar criticamente a adoção das práticas de SI por parte dos fornecedores	• Definir os requisitos de SI a serem aplicados aos fornecedores e incluídos em termos e contratos • Decidir sobre sanções e punições, a serem aplicadas aos fornecedores, conforme termos previstos em contrato, em casos de violações de SI.

e) Planejamento e preparação da gestão de incidentes da segurança da informação (A.5.24)

Responsabilidade	Autoridade
• Avaliar e sugerir a adoção ou substituição de ferramentas e mecanismos para detecção de incidentes da SI • Planejar a realização de testes de simulação de incidentes de SI	• Definir o conteúdo do procedimento de planejamento e preparação da gestão de incidentes da SI (PG-15)

f) Avaliação e decisão sobre eventos da segurança da informação (A.5.25)

Responsabilidade	Autoridade
• Analisar os relatos de eventos de SI com base nos critérios definidos no (PG-15) • Sugerir quais informações sobre o incidente de SI serão comunicadas ao público interno e externo e como isso será feito.	• Decidir se os eventos relatados constituem incidentes de SI e atribuir o nível de criticidade ao incidente • Decidir sobre a necessidade de comunicar incidentes à ANPD

g) Resposta a incidentes de segurança da informação (A.5.26)

Responsabilidade	Autoridade
• Coordenar o processo de investigação e resposta a incidentes de SI • Subsidiar a área jurídica com informações relevantes para atuação em ações judiciais • Revisar o Comunicado de Incidente de Segurança antes do envio à ANPD,	• Acessar <i>logs</i> com a finalidade de analisar incidentes de SI • Decidir as ações a serem tomadas no âmbito da resposta a incidentes de SI, incluindo a necessidade de contratação de especialistas

quando aplicável

h) Aprendizado com incidentes de segurança da informação (A.5.27)

Responsabilidade	Autoridade
Onde necessário: • Providenciar a revisão nas matrizes de risco como resultado do aprendizado com incidentes de SI • Revisar tecnicamente o conteúdo de políticas de SI associadas ao tratamento de incidentes, quando necessário. • Disseminar, como apropriado, as lições aprendidas com a força de trabalho	• Decidir sobre a implementação de medidas adicionais de proteção

i) Coleta de evidências (A.5.28)

Responsabilidade	Autoridade
• Preservar as evidências coletadas no âmbito da investigação de incidentes de SI. • Organizar a documentação sobre quais evidências foram utilizadas, mantendo a devida rastreabilidade	• Coletar evidências para investigação de incidentes de SI

j) Segurança da informação durante a interrupção (A.5.29)

Responsabilidade	Autoridade
• Monitorar a eficácia das medidas de segurança da informação durante a interrupção • Revisar tecnicamente o conteúdo dos Planos de contingência	• Tomar decisões sobre a priorização dos recursos de segurança da informação durante a interrupção, garantindo que as medidas de proteção previstas nos Planos de Contingência sejam implementadas e mantidas

k) Prontidão de TIC para continuidade de negócios (A.5.30)

Responsabilidade	Autoridade
• Identificar, analisar e avaliar o risco da interrupção de atividades prioritárias da organização e os processos, sistemas, informações, pessoas, bens, fornecedores e outros recursos que as apoiam. • Planejar a realização de testes dos	• Definir a necessidade de elaboração de Planos de contingência

l) Requisitos legais, estatutários, regulamentares e contratuais (A.5.31)

Responsabilidade	Autoridade
• Revisar o inventário de normas técnicas e legais relacionadas à SI • Avaliar a necessidade de ações para suprir eventuais lacunas de atendimento aos requisitos técnicos e legais • Sugerir medidas para garantir a conformidade com os requisitos técnicos e legais	• Tomar decisões sobre a implementação de medidas e controles para atender aos requisitos de conformidade.

m) Direitos de propriedade intelectual (A.5.32)

Responsabilidade	Autoridade
• Revisar o inventário de ativos de informação sujeitos à requisitos de direitos de propriedade intelectual • Conscientizar a força de trabalho sobre a necessidade de preservar os direitos de propriedade intelectual	• Decidir sobre ações relacionadas a violações dos requisitos de direitos de propriedade intelectual, incluindo processos disciplinares (ver A.6.04)

n) Análise crítica independente da segurança da informação (A.5.35)

Responsabilidade	Autoridade
• Conduzir análises críticas independentes da segurança da informação para avaliar a eficácia dos controles existentes, identificar lacunas e propor melhorias, a serem realizadas conforme IT específica	• Definir o cronograma e planejamento da análise crítica • Decidir sobre o que constitui uma não-conformidade que deverá ser tratada pelos envolvidos

o) Compliance com políticas, regras e normas para segurança da informação (A.5.36)

Responsabilidade	Autoridade
• Avaliar a necessidade de ações para suprir eventuais lacunas de atendimento às políticas, regras e normas • Sugerir medidas para garantir a conformidade com as políticas e normas	• Tomar decisões sobre a implementação de medidas e controles para atender aos requisitos de conformidade.

p) Processo disciplinar A.6.04

Responsabilidade	Autoridade
• Analisar casos de violações nas políticas e regras de segurança da informação	• Definir as sanções associadas a violações nas políticas e regras de segurança da informação.

q) Trabalho remoto A.6.07

Responsabilidade	Autoridade
• Revisar tecnicamente o conteúdo do Termo aditivo ao contrato de trabalho para a validação do home office • Supervisionar a implementação e adoção de práticas seguras de trabalho remoto • Conscientizar a força de trabalho sobre a necessidade de cumprir aos requisitos de segurança para trabalho remoto.	• Estabelecer requisitos de segurança para dispositivos utilizados em trabalho remoto, como laptops, dispositivos móveis e acesso remoto seguro.

r) Relato de eventos de segurança da informação (A.6.08)

Responsabilidade	Autoridade
• Receber e analisar os relatos de eventos de Segurança da Informação • Comunicar à força de trabalho a importância de relatar eventos de segurança da informação, orientando-a sobre os canais apropriados	• Definir quais são os canais mais apropriados para que a força de trabalho realize o relato dos eventos

s) Gestão de vulnerabilidades técnicas (A.8.08)

Responsabilidade	Autoridade
• Realizar análises de vulnerabilidades e ameaças, usando ferramentas de inteligência de ameaças (A.5.07).	• Autorizar a realização de testes de vulnerabilidade • Tomar decisões para priorizar e tratar as vulnerabilidades identificadas, implementando medidas de mitigação e acompanhando seu progresso.

t) Gestão de mudanças

Responsabilidade	Autoridade
• Realizar análise de mudanças planejadas, no âmbito da SI, subsidiando as decisões sobre a viabilidade de implementá-las • Participar do planejamento da implementação das mudanças, no âmbito da SI. • Analisar criticamente as consequências de mudanças não intencionais e encaminhar seu tratamento. • Avaliar o resultado atingido, comparando com o resultado esperado (eficácia)	• Decidir se os resultados da implementação das mudanças foram eficazes, do ponto de vista da SI.

7. DINÂMICA DE TRABALHO DO CSI

O CSI deverá ser reunir ordinariamente bimestralmente, para tratar da seguinte **pauta mínima**:

- Andamento das atividades (“backlog”)
- Acompanhar o alcance dos objetivos de segurança da informação associados às diretrizes das políticas de SI
- Analisar criticamente a adoção das práticas de SI por parte dos fornecedores e decidir sobre sanções e punições, a serem aplicadas aos fornecedores, conforme termos previstos em contrato, em casos de violações de SI.
- Discutir lições aprendidas sobre a resposta a incidentes de SI no período e como incorporá-las no dia-a-dia da organização.
- Discutir sobre requisições de mudança que afetem a SI
- Analisar casos de violações nas políticas e regras de segurança da informação

As demais atribuições do CSI poderão ser cumpridas através do grupo de trabalho no Bitrix que permite a comunicação contínua entre os membros, ou mediante reuniões extraordinárias.

8. REGISTROS

Todas as deliberações e assuntos tratados em uma reunião do CSI devem ser formalizados em ata de reunião, utilizando as funcionalidades existentes no Bitrix.

Deve constar na ata:

- os nomes dos membros participantes da reunião e participantes convidados;
- os nomes dos membros ausentes;
- os assuntos tratados;
- o plano de ação e a lista de atividades (backlog).